

KDNA Sentinel — Instruction Manual

KDNA Sentinel is a two-module WordPress security plugin for small-agency client sites:

- **Guard** — stops AI-written and bot form spam on KDNA Forms and WooCommerce account forms.
- **Watch** — monitors installed plugins against a known-vulnerability database and warns when a site is running something with an unpatched security hole.

An optional **Hub** lets client sites report their Watch results to one central KDNA dashboard.

Each module is switched on or off independently. The plugin is deliberately not a firewall — it complements edge tools (Cloudflare, Wordfence, etc.) by covering the two gaps they leave: form spam and plugin patch-lag.

1. Installing and activating

1. In WordPress admin, go to **Plugins** → **Add New** → **Upload Plugin**.
2. Upload `kdna-sentinel-<version>.zip` and click **Install Now**, then **Activate**.
3. A new **KDNA Sentinel** item appears in the admin sidebar (shield icon).

On activation the plugin creates its three database tables (quarantine, vulnerability cache, hub log) and schedules its background jobs. Both modules start **off** — nothing is inspected or scanned until you enable them.

2. Guard — form-spam defence

Open **KDNA Sentinel** → **Guard**.

Enabling

- **Guard module** — tick **Enable Guard**. When off, no form submissions are inspected.

Guard evaluates every protected submission and reaches one of three verdicts: **PASS** (let through), **BLOCK** (quarantined), or **BORDERLINE** (sent to the optional Claude scorer, if configured). It always *fails open* — if anything errors, the submission is let through rather than lost.

Heuristics (the free checks)

- **Honeypot** — injects a hidden field; any submission that fills it is blocked. Leave on unless a form breaks.

- **Time-to-submit threshold** — submissions completed faster than this many seconds are blocked as automated. Default **2**. Set **0** to disable.
- **IP blocklist** — one IP address per line; submissions from these IPs are blocked outright. Invalid entries are dropped on save.
- **Country blocklist** — pick the countries to block from the multi-select list (hold Ctrl / Cmd to choose several); submissions from the chosen countries are blocked outright. Select none to disable the check. The visitor country is read from a Cloudflare / CloudFront header when present, otherwise from WooCommerce's bundled geolocation database; when it can't be determined the check is skipped. Only block countries the site has no legitimate audience in.

Claude API borderline scorer (optional)

Only *borderline* submissions are sent to the Claude API, and only the message body — never the full submission or personal data. On any API error the submission is let through.

- **Anthropic API key** — stored server-side, never shown again in full. Without a key, borderline submissions are simply let through.
- **Model** — a fast Haiku-class model is recommended. Default `claude-haiku-4-5`.
- **HAM confidence threshold** — a borderline submission is let through only when the API judges it genuine with at least this confidence (0–1). Default **0.5**.
- **Daily API call cap** — maximum API calls per day so a spam flood can't run up cost. Default **100**. Set **0** for no limit.

Quarantine

Every blocked submission is held under the Guard tab with a **Preview**. Row actions:

- **This was genuine — let it through** — re-runs the genuine path (KDNA Forms entries are un-flagged and re-notified; other sources email the admin the captured details).
- **Delete** — removes the held row.
- **Block this IP** — adds the submission's IP to the IP blocklist.

Held rows are automatically purged after 30 days.

3. Watch — plugin patch-lag monitoring

Open **KDNA Sentinel** → **Watch**.

Enabling and provider

- **Watch module** — tick **Enable Watch**.
- **Vulnerability provider** — choose one:
- **WPScan** — requires an API key (free tier is capped).

- **Patchstack** — requires an API key.
- **Wordfence Intelligence (free, no key)** — the vulnerability feed is free and open; no key required (an optional key only raises rate limits).
- **Provider API key** — required for WPScan and Patchstack; optional for Wordfence. Stored server-side, never shown again in full.
- **Vulnerability data refresh** — how often to download a fresh copy of the vulnerability data: **Every 6 hours**, **Every 12 hours (recommended)**, or **Once a day**. Only applies to the Wordfence provider (WPScan and Patchstack are checked live on every scan). More frequent is more current but uses more bandwidth on each site.

Scanning and the dashboard

A scan runs automatically once a day, and you can trigger one any time with **Scan now**. Results appear worst-first: plugin, installed version, severity, the version it's fixed in, how long the fix has been available (patch lag), and an update link. If nothing is at risk you get an "All plugins current" message.

Alerts

- **Digest recipients** — comma-separated addresses for the summary digest. Blank uses the WordPress admin email.
- **Critical alert recipients** — comma-separated addresses for immediate URGENT critical-vulnerability alerts. Blank uses the admin email.
- **Digest frequency** — **Weekly** or **Daily**.
- **Digest when clean** — tick to skip the digest when nothing is at risk.
- **Instant critical alerts** — email immediately when a scan newly detects a critical vulnerability (de-duplicated so the same CVE doesn't re-alert).

4. Hub — optional central reporting (off by default)

Open **KDNA Sentinel** → **Hub**. Only plugin/version/vulnerability *metadata* is ever transmitted — never submission content or personal data — and all hub traffic is HMAC-signed with a shared secret.

On a client site (reporting in)

- **Report to KDNA hub** — after each scan, send a signed summary to the hub.
- **Hub URL** — the base URL of the KDNA hub site.
- **Shared secret** — the same secret must be set on the client and the hub.

On the hub site (receiving)

- **This site is the KDNA hub** — exposes the report endpoint (`/wp-json/kdna-sentinel/v1/report`) and shows the master dashboard: every reporting site with its worst severity, at-risk count, longest patch lag and last check-in, red-flagging any site with a critical vulnerability or a stale check-in.
-

5. Developer customisations

Change how often the Wordfence feed refreshes

The **Vulnerability data refresh** dropdown offers 6 / 12 / 24 hours. For any other interval, use the `kdna_sentinel_watch_wordfence_cache_ttl` filter — it returns the cache lifetime in seconds and always overrides the dropdown. Add it to a small mu-plugin, or your theme's `functions.php` :

```
// Refresh the Wordfence vulnerability feed every 6 hours.
add_filter( 'kdna_sentinel_watch_wordfence_cache_ttl', function () {
    return 6 * HOUR_IN_SECONDS;
} );
```

Return any number of seconds — for example `3 * HOUR_IN_SECONDS` for three hours, or `DAY_IN_SECONDS` for once a day. This only affects the Wordfence Intelligence provider; WPScan and Patchstack are queried live on every scan.

Other hooks

- `kdna_sentinel_guard_borderline_is_spam` (filter) — decide a borderline submission yourself (the Claude scorer hooks this).
 - `kdna_sentinel_guard_blocked` (action) — fires when Guard blocks a submission, with the verdict and metadata.
 - `kdna_sentinel_guard_release` (filter) — fully handle release of a quarantined submission for any source.
-

6. Frequently asked questions

Does this replace Wordfence or Cloudflare? No. Sentinel is not an edge firewall and does not block traffic. It complements those tools by covering form spam and plugin patch-lag. (If a client already runs the Wordfence plugin, the vulnerability data is the same source — Sentinel's value there is the central Hub view across all your sites, which Wordfence doesn't provide.)

Will Guard ever lose a genuine enquiry? No — Guard fails open. If any check errors, the submission is let through, and anything it does block is held in the quarantine for one-click release.

Does anything leave the site? Only when you opt in: the Claude scorer sends the message body (no PII) if you add an API key; Watch queries your chosen vulnerability provider; and the Hub sends metadata-only, HMAC-signed scan summaries if you enable reporting.